

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

Q.1 Pick any one app you use daily (such as Instagram, Zomato, or PhonePe) and list 5 security measures it likely uses to protect user data.

ANS :

Here are 5 security measures **Zomato** uses to protect user data:

1. **HTTPS / TLS Encryption:** Encrypts all data sent between the app and servers to prevent interception.
2. **OTP-Based Authentication:** Uses temporary SMS verification codes instead of relying solely on passwords.
3. **PCI-DSS Compliant Payment Gateways:** Process credit/debit card transactions securely via external, certified payment providers without saving raw card details.
4. **Tokenized Login Sessions:** Uses secure JWT tokens for sessions, allowing users to log out remotely from all devices if compromised.
5. **Data Anonymization:** Hides user phone numbers from delivery partners using masked proxy numbers to protect user privacy.

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

Q.2 Choose either the NIST Cybersecurity Framework, ISO 27001, or CIS Controls. For each of the 5 security measures you listed in the previous task, map it to the most relevant category or control in your chosen framework. Hint :For example, 'two-factor authentication' might map to 'Access Control' in CIS or 'Protect' in NIST.

ANS :

Mapping the 5 security measures for Zomato to the NIST Cybersecurity Framework (CSF 2.0):

#	Security Measure	NIST CSF 2.0 Category	Category Code	How It Maps
1	HTTPS / TLS Encryption	Data Security	PR.DS (<i>Protect</i>)	Protects sensitive data in transit using strong cryptographic protocols.
2	OTP-Based Authentication	Identity Management, Authentication, and Access Control	PR.AA (<i>Protect</i>)	Enforces identity verification and multi-factor authentication mechanisms.
3	PCI-DSS Compliant Payment Gateways	Cybersecurity Supply Chain Risk Management (<i>and Data Security</i>)	GV.SC (<i>Govern</i>) PR.DS (<i>Protect</i>)	Mandates third-party vendor compliance and secures processing of sensitive payment data.

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

#	Security Measure	NIST CSF 2.0 Category	Category Code	How It Maps
4	Tokenized Login Sessions	Identity Management, Authentication, and Access Control	PR.AA (Protect)	Manages active user sessions safely and provides immediate session revocation capabilities.
5	Data Anonymization (Phone Number Masking)	Data Security	PR.DS (Protect)	Protects user privacy at rest and in transit by minimizing exposure of Personally Identifiable Information (PII).

Q.3 Given this scenario: A new food delivery app wants to prevent unauthorized access, protect payment info, and ensure customer privacy. Select 3 controls from the CIS Controls framework that would address these concerns and explain how each control helps.

ANS : Here are 3 CIS Controls (v8) that address those concerns:

1. CIS Control 6: Access Control Management (Prevents Unauthorized Access)

Enforces strong multi-factor authentication (MFA/OTP) for users and admins, manages user session tokens, and restricts backend administrative access. This ensures only verified users and authorized staff can enter accounts or systems.

2. CIS Control 3: Data Protection (Protects Payment Info)

Mandates data encryption in transit (TLS) and integration with PCI-DSS compliant payment gateways. Tokenizing payment details ensures raw credit card and banking numbers are never stored in plain text, making intercepted data unreadable to attackers.

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

3. CIS Control 14: Security Awareness and Skills Training (Ensures Customer Privacy)

Educates employees, customer support teams, and delivery agents on privacy protocols and data-handling practices (such as phone number masking). This prevents insider misuse, accidental leaks, and social engineering attacks that target customer PII.

Q.4 Create a comparison table with three columns (NIST, ISO 27001, CIS Controls) and list 3 unique features or strengths of each framework based on your research. Hint: Focus on what makes each framework different or especially useful for certain organizations.

ANS :

Feature / Strength	NIST Cybersecurity Framework (CSF)	ISO 27001	CIS Controls
1. Primary Focus & Objective	Outcome & Risk Management: Focuses on standardizing risk outcomes across 6 core functions (Govern, Identify, Protect, Detect, Respond, Recover).	Management System (ISMS): Focuses on establishing a formal, top-down Information Security Management System for continuous compliance.	Technical Execution: Focuses on actionable, technical, and defense-in-depth safeguards against specific cyber attack vectors.
2. Structuring & Prioritization	Maturity Tiers & Profiles: Uses Tiers (1–4) and Current/Target Profiles to let organizations phase implementation based on risk appetite.	Global Audit Certification: Offers a formal third-party audit and certification process recognized internationally to build buyer trust.	Implementation Groups (IGs): Categorizes safeguards into IG1 (Essential Cyber Hygiene), IG2, and IG3 based on enterprise size and resource constraints.

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

Feature / Strength	NIST Cybersecurity Framework (CSF)	ISO 27001	CIS Controls
3. Implementation & Cost	Free & Adaptable Guidelines: Completely free to access and voluntary, offering flexibility with no mandatory audit fees.	Rigorous Policy Framework: Requires formal documentation, external audit investments, and mandatory management oversight cycles.	Prescriptive & Ordered: Provides a step-by-step prioritized checklist designed for immediate, concrete execution.

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

Q.5 Use ChatGPT or another AI tool to generate a checklist of 5 security actions a small e-commerce startup should take according to the ISO 27001 framework. Copy the AI's response and briefly comment on whether you agree with each item and why.

ANS : Here is a 5-step ISO 27001 security checklist for a small e-commerce startup, followed by a brief analysis and evaluation for each action item.

ISO 27001 Security Checklist for a Small E-Commerce Startup

1. Conduct an Information Security Risk Assessment (ISO 27001 Clause 6.1.2)
 - Identify and catalogue sensitive assets (customer databases, payment APIs, source code, hosting infrastructure) and evaluate the risks, vulnerabilities, and potential threats to each asset.
2. Establish Access Control & Identity Management Policies (ISO 27001 Annex A.5.15–A.5.18)
 - Implement the principle of least privilege, enforce multi-factor authentication (MFA) across all administrative portals, and enforce strict user access revocation processes for departing staff.
3. Implement Data Protection & Cryptographic Controls (ISO 27001 Annex A.8.24)
 - Encrypt all sensitive data in transit (TLS 1.2/1.3 for customer transactions) and at rest (customer PII and database storage), ensuring encryption keys are securely managed.
4. Define & Test an Incident Management Procedure (ISO 27001 Annex A.5.24–A.5.28)
 - Create a documented incident response process detailing how to detect, report, contain, and recover from security breaches or payment gateway outages.
5. Establish Supplier & Third-Party Relationship Security (ISO 27001 Annex A.5.19–A.5.22)

ASSIGNMENT : 3 – SECURITY FRAMEWORKS

GUIDED BY : VIPUL MISTRI

- Assess and monitor the security posture of third-party vendors (hosting providers, payment processors, analytics plugins) to ensure they comply with baseline security standards.

Review & Commentary

1. Information Security Risk Assessment

- Agree: Yes. A startup cannot secure what it doesn't know it owns. A risk assessment prevents overspending on low-risk areas while ensuring critical vectors (like payment databases) are prioritized.

2. Access Control & Multi-Factor Authentication

- Agree: Yes. Compromised credentials are the leading cause of startup data breaches. Enforcing MFA and least-privilege access is one of the highest-ROI security actions a startup can take.

3. Data Protection & Cryptographic Controls

- Agree: Yes. E-commerce platforms handle payment details and customer PII. Encryption in transit and at rest is essential to prevent data theft and comply with privacy regulations like GDPR or PCI-DSS.

4. Incident Management Procedure

- Agree: Yes. Without an established incident response plan, startups waste valuable time scrambling during a breach, leading to extended downtime, greater data loss, and severe reputational damage.

5. Supplier & Third-Party Relationship Security

- Agree: Yes. E-commerce platforms rely heavily on third-party integrations (payment gateways, inventory tools, shipping APIs). A vulnerability in a third-party plugin can compromise the entire store, making vendor vetting crucial.